

FARI

Framework Specification

Framework for Aerospace Research and Investigation v1.3.0

Canonical specification, glossary, workflow, and release guidance

FARI v1.3.0 | 2026-08-23

This is the versioned release edition of the FARI documentation bundle. Canonical working sources for this release are stored under the same version folder.

Canonical specification for FARI v1.3.0

Purpose

FARI is the executive and traceability layer for aerospace security research. It does not replace the technical method used by an auditor. Instead, it gives the report author one consistent way to frame the scope, normalize evidence, connect findings to mission meaning, and conclude each investigation in a way that can be read quickly by technical and executive audiences.

The design goal is simple:

- let the attacker or external auditor work in their own format;
- keep the extra reporting burden on the FARI report author, not on the evidence producer;
- preserve uncertainty instead of hiding it;
- produce one investigation report per claim and one consolidated report for the whole assessment.

Core principles

1. **Method agnostic.** Firmware review, RF testing, FlatSat validation, cloud review, reverse engineering, and emulation can all feed the same framework.
2. **Evidence before interpretation.** Facts, assertions, inferences, assumptions, contradictions, and gaps are different things and must stay separated.
3. **Mission-aware conclusions.** A lab exploit and an on-orbit mission effect are not the same conclusion.
4. **No hidden score.** FARI does not depend on CVE, CVSS, CWE, or a numeric average. It uses qualitative decisions that can still be aggregated.
5. **External-auditor friendly.** An external tester does not need to know FARI and should not be forced to complete a FARI form.
6. **Closed means immutable.** Once an investigation or assessment is closed, it becomes a final record. New work should create a new revision or follow-on assessment.

Roles

Technical reporter

The technical reporter is the person or team that produced the evidence. This can be an internal researcher, external red team, lab engineer, hardware analyst, RF specialist, or software auditor.

The technical reporter is responsible for the technical work and the fidelity of their evidence, but not for FARI normalization or executive framing.

Report author

The report author transforms supplied material into FARI records. In the web application this role is currently fixed as *Fari-Agent*.

The report author is responsible for:

- defining the Frame;

- translating raw material into normalized sections;
- deciding sufficiency and conclusion states;
- relating findings to technical meaning and optional framework references;
- generating investigation and consolidated reports.

Client or mission owner

The client or mission owner provides the business and mission context that makes the conclusions meaningful. They are also the consumer of the final result.

Lifecycle

FARI has four phases:

1. **Frame**
2. **Acquire**
3. **Relate**
4. **Inform**

The web workflow and the manual template use the same sequence.

In the current web workspace, those phases are also presented as a horizontal workflow timeline directly under the page hero so the report author can see the current state without losing screen space to a permanent side rail.

Current web contract

The current web implementation is the reference execution of this workflow. Its machine-readable contract is recorded in `spec/current/fari.manifest.yml` and is consumed by the application templates, validation helpers, and parity checks. The web workspace also provides:

- English and Spanish interface and report labels through editable JSON dictionaries;
- an editable language review page so technical terms can intentionally remain in English;
- a dedicated asset workspace for source files, normalized inventory, and related investigations;
- captured revisions and difference review for assessment fields, assets, investigations, asset sources, and inventory components;
- no independent source-inventory area outside the related asset.

User-entered narratives, evidence content, and stable FARI identifiers are not translated. Only interface labels, controlled value labels, and generated report labels use the selected language.

The web contract uses these controlled values: assessment status `draft` or `closed`; report maturity `draft`, `provisional`, `final`, or `superseded`; investigation status `draft`, `ready`, or `closed`; and asset access basis `private`, `public`, or `other`. Asset segments and coverage values are the sets listed in Frame. Sufficiency uses `sufficient`, `partial`, or `insufficient`; finding state uses `candidate`, `confirmed`, `observation`, `remediated`, or `verified_closed`; and mapping state uses `candidate`, `confirmed`, or `not_applicable`.

Traceability and revisions

FARI assessments can evolve as evidence is added, findings are normalized, asset source inventory changes, and closure reviews happen. For that reason, FARI supports explicit assessment revisions.

What a revision is

A revision is a captured snapshot of the assessment state at a meaningful moment. It is not the same thing as every keystroke or every save.

Typical revision points:

- after a major evidence intake;
- after findings and optional framework mappings are normalized;
- after a meaningful asset source refresh;
- before executive review;
- automatically when the assessment is closed.

Why revisions matter

Revisions answer questions such as:

- what changed between the draft and the final assessment;
- when a claim conclusion changed;
- when a source import changed a recorded component version;
- whether a final report corresponds to a known assessment state.

Revision rules

- The assessment identifier remains stable.
- The revision label changes, for example v1, v2, v3.
- A closed assessment should always have a final captured revision.
- A revision stores structure and traceability, not just a static rendered report file.

Difference review

FARI should be able to compare one revision against another revision or against the current working state. At minimum, the comparison should show changes in:

- assessment fields;
- assets;
- investigations and conclusions;
- asset source files attached to the relevant asset;
- inventory components and their tracked status.

Frame

The Frame defines what is being evaluated and under which limits. If the Frame is vague, the rest of the report becomes hard to defend.

Fields in the Frame

Client name

The organization or mission owner that requested the work.

Fill it with the exact name that should appear in the report.

Assessment title

A short label for the engagement. It should identify the system, campaign, or focus area, for example `SpaceCAN Replay Resistance Review`.

Mission context

A concise explanation of where this assessment matters. This should describe the system role, environment, mission stage, or operational importance.

Good example:

Lab validation of the telemetry monitoring path for a representative spacecraft bus interface before integrated vehicle testing.

Scope

The technical boundary of the work. This is one of the most important fields in FARI because it defines what the conclusions actually mean.

Include:

- in-scope assets;
- environments;
- interfaces;
- data paths;
- known limits of access.

Avoid broad claims such as `entire spacecraft security`.

Authorization

What permission made the work legitimate. If special handling, RF windows, or test approvals were required, state them here.

Exclusions

Anything explicitly out of scope. This protects the report from being read as a claim about systems that were never tested.

Assets

Each asset should be specific enough to be referenced by evidence and findings.

At minimum, each asset should have:

- name;
- segment;
- access basis;
- coverage state;
- short description.

Recommended segment values are:

- space
- ground
- link
- user
- supply_chain
- cloud
- other

Use the segment that best describes where the assessed exposure primarily exists. For example, a mission API gateway or hosted processing backend should normally be recorded as `cloud`, even if it supports a space or ground mission function.

Use `other` when the asset is an intentional combination of segments or does not fit the predefined set cleanly.

Recommended access values are:

- `public`
- `private`
- `other`

Use `public` when the material or exposure was obtainable through internet reachability, OSINT, partner-visible interfaces, third-party disclosures, or other non-restricted sources.

Use `private` when the material or exposure required authorized internal access, lab access, source access, customer-provided credentials, or restricted mission documentation.

Use `other` when the access path is mixed, inherited from several parties, or does not fit cleanly into a public/private distinction.

Claim description

The claim is the expected secure behavior being tested. It should be testable, not aspirational.

Good claim:

The monitor distinguishes forged reply-like frames before presenting them as trusted state.

Weak claim:

The system is secure against spoofing.

The claim should be narrow enough that `Meets`, `Does Not Meet`, or `Inconclusive` mean something precise.

Acquire

Acquire is where raw material becomes normalized assessment content. This is the phase that most clearly separates the external auditor from the report author.

The external auditor can deliver screenshots, packet captures, notes, logs, scripts, lab observations, or a finished technical report. The report author is the one who transforms that material into FARI language.

Evidence

Evidence files are the preserved artifacts. Each one should have a short description and remain attached to the related investigation.

Examples:

- packet capture;
- screenshot;
- tool output;
- script;
- document from an external auditor.

Asset source inventory

FARI treats technical source files as first-class supplied material attached to the asset they describe. This includes structured dependency inventories, firmware images, binaries, RF captures, SigMF metadata/data, packet captures, documents, logs, and other source formats.

An asset source upload creates a source record that:

- preserves the supplied bytes and SHA-256 hash;
- records the original filename, media type, size, and detected format;
- optionally creates an **inventory component** record for each dependency or package when the format supports structured extraction.

The current detected format values are:

`cyclonedx`, `spdx`, `package-lock`, `dependency-map`, `text-list`, `jsonl`, `jsonl-components`, `sigmf-meta`, `sigmf-data`, `binary`, `pcap`, `pcapng`, `elf`, `hex`, `csv`, `tsv`, `yaml`, `xml`, `pdf`, `doc`, `docx`, `xls`, `xlsx`, `text`, `json`, and `empty`.

The source parser normalizes components from CycloneDX, SPDX, package-lock, dependency-map, package-style text lists, and component-shaped JSONL records. JSONL event logs, RF captures, SigMF data, firmware, binaries, packet captures, documents, archives, and unsupported technical formats remain preserved raw source material and are not represented as dependency components. A new source is uploaded through an asset and receives an **SRC-** identifier; generated component and inventory-event records use **CMP-** and **SBE-** identifiers.

This lets the report author answer both:

- what file was supplied for the asset; and
- what component state FARI currently believes is true, when applicable.

Inventory component timeline

Each component can accumulate events over time, for example:

- imported from an asset source;
- vulnerability detected;
- version updated;
- status changed;
- fix verified;
- analyst note.

This timeline is what allows FARI to say:

- which version was present when the vulnerability was observed;
- when the version changed;
- whether the fix was only applied or also verified.

Facts

Facts are statements directly supported by evidence.

Good fact:

A forged frame was transmitted onto the local bus.

Not a fact unless directly shown:

The flight computer trusted the forged command.

Assertions

Assertions are statements supplied by the technical reporter that are useful but not independently demonstrated by the report author.

Example:

The bytes 01 FF represent a valid thruster-state response for node 0x04.

Inferences

Inferences are report-author interpretations derived from the evidence and context.

Example:

The display can be influenced by attacker-controlled traffic in the tested environment.

Assumptions

Assumptions are conditions treated as true for the purpose of the analysis even though they are not demonstrated by current evidence.

Example:

Operators may use the displayed values for operational decisions.

Contradictions

Contradictions record conflicts that matter to the conclusion. They should not be hidden inside the narrative.

Example:

The screenshot suggests a changed value, but the provided notes do not state whether the field is decoded or raw.

Gaps

Gaps are the missing information that prevents a stronger conclusion.

Examples:

- no proof of production deployment path;
- no configuration confirming freshness validation;
- no evidence of physical actuator effect.

Sufficiency fields

FARI uses three sufficiency decisions:

Technical sufficiency

Whether the evidence is enough to conclude the technical condition under test.

- **Sufficient**: enough to conclude the technical behavior.
- **Partial**: enough for part of the behavior, but not all of it.

- **Insufficient:** not enough to conclude the condition.

Reachability sufficiency

Whether the path to exploitation or exposure is supported within the current scope.

This is what prevents a lab-only result from silently becoming an operational reachability claim.

Mission sufficiency

Whether the consequence to mission or operations is directly shown, partially supported, or still speculative.

Relate

Relate turns normalized material into findings, scenarios, and framework references.

Findings

A finding is the reportable condition that came out of the investigation. The finding can be broader or narrower than a single evidence file, but it should still map cleanly to the claim being evaluated.

Each finding should contain:

- a concise title;
- state;
- condition text;
- observed effect;
- credible impact;
- optional framework mapping and rationale.

Relationship between findings and inventory

Asset source inventory does not replace a finding.

Use the inventory when tracking package/component state over time. Use a finding when there is a reportable condition that contributes to a claim conclusion.

Example:

- inventory event: `openssl` moved from 3.0.9 to 3.0.14;
- finding: vulnerable dependency handling permits deployment of a version with a known exploitable weakness.

Inform

Inform is where the report author decides what the investigation means and what the client should do next.

Conclusion

The FARI conclusion is about whether the claim was satisfied within the stated scope.

Allowed values:

- Meets
- Does Not Meet
- Inconclusive
- Not Assessed

How to choose the conclusion

Use **Meets** when the available evidence supports that the expected behavior holds within the declared boundary.

Use **Does Not Meet** when the available evidence supports that the expected behavior failed within the declared boundary.

Use **Inconclusive** when the current evidence cannot resolve the claim and more work is needed.

Use **Not Assessed** when the claim has not truly been evaluated yet.

Scenario disposition

Scenario disposition is separate from the claim conclusion. It describes the broader attack path or risk story.

Allowed values:

- Demonstrated
- Plausible
- Not Demonstrated
- Not Evaluated

This distinction is important. A claim can conclude **Does Not Meet** for a lab monitoring path while the broader attack scenario remains only **Plausible** because operational reachability or mission consequence is not yet proven.

Confidence

Confidence expresses how strong the report author believes the current evidence base is.

- High
- Medium
- Low

Required action

Required action is the executive next step.

Allowed values:

- Accept
- Remediate
- Extend Investigation
- Retest

- No Action

Recommended interpretation:

- Accept when the claim is satisfied and there is no corrective work.
- Remediate when a corrective action is needed.
- Extend Investigation when scope or evidence must grow before closing the question.
- Retest when a condition or fix must be validated again.
- No Action when there is nothing meaningful to do from the current result.

Priority

Priority is a simple qualitative ordering for action:

- Immediate
- Planned
- Routine
- None

Scope boundary

This field explains exactly where the conclusion applies. It should be written as a sentence, not just a label.

Good example:

Conclusion applies to supplied lab replay and spoofing evidence affecting the SpaceCAN monitor path only; physical response, production controls, and on-orbit behavior were not assessed.

Rationale

The rationale is the shortest defensible explanation of why the selected conclusion is correct.

Recommendations

Recommendations describe what should happen next in engineering or assessment terms.

Acceptance criteria

Acceptance criteria define what evidence would allow the issue to close or the claim to be revalidated.

Closure rules

An investigation should close only when it has:

- a clear claim;
- evidence or normalized supplied material;
- a selected scenario disposition;
- a valid conclusion and required action combination;

- rationale and scope boundary;
- enough context that a reader can understand the decision without reopening the raw evidence set immediately.

An assessment should close only when:

- its scope is defined;
- assets are registered;
- at least one gating investigation exists;
- all gating investigations are closed.

Consolidated reporting

FARI does not stop at individual investigations. It also produces one final assessment-level view.

The consolidated report should:

- identify the client and scope;
- summarize assets;
- list all investigations;
- totalize conclusions and scenario dispositions;
- show required actions;
- provide one overall conclusion for the assessment.

The overall conclusion is derived from gating investigations:

1. if any gating investigation is **Does Not Meet**, the assessment is **Does Not Meet**;
2. otherwise, if any gating investigation is **Inconclusive** or **Not Assessed**, the assessment is **Inconclusive**;
3. otherwise, it is **Meets**.

This preserves clarity without creating a misleading average score.

Traceable inventory example

Assume an asset source import registers:

- component **libfoo**
- current version **1.4.2**
- status **Tracked**

Later, a reviewer records:

- event type: **Vulnerability Detected**
- vulnerability ID: **CVE-2026-0001**
- status after: **Vulnerable**

After engineering updates the package:

- event type: Version Updated
- from version: 1.4.2
- to version: 1.4.5
- status after: Update In Progress

After retest:

- event type: Fix Verified
- to version: 1.4.5
- status after: Fixed

This is different from a normal finding because the timeline is centered on the component lifecycle, not only on one investigation claim.

Simple worked example

This example shows how a small manual assessment should be filled.

Scenario

A lab monitor receives SpaceCAN traffic. The supplied evidence shows that a forged frame changes the displayed value.

Frame entries

- Client name: Example Aerospace
- Assessment title: SpaceCAN Monitor Validation
- Mission context: Lab validation before integrated system testing
- Scope: SpaceCAN monitor display path in representative lab bus
- Exclusions: No physical actuator validation and no on-orbit behavior
- Claim: The monitor distinguishes forged reply-like frames before presenting trusted state

Acquire entries

- Facts:
 - Forged traffic was transmitted
 - The displayed value changed from 12 to 255
- Assertions:
 - The message bytes represent a reply-like telemetry field
- Inferences:
 - The display can be influenced by attacker-controlled traffic in the tested path
- Gaps:

- No proof of operational reachability
- No proof of physical effect
- Technical sufficiency: Sufficient
- Reachability sufficiency: Partial
- Mission sufficiency: Partial

Relate entries

- Finding title: Forged reply-like frame influences displayed telemetry
- Framework mapping: optional external reference, if one is required by the engagement
- Mapping state: Confirmed

Inform entries

- Conclusion: Does Not Meet
- Scenario disposition: Plausible
- Confidence: Medium
- Required action: Remediate
- Priority: Immediate
- Scope boundary: Lab monitor path only
- Rationale: The tested display accepted attacker-controlled traffic as trusted state

This is a good example of a report that is conclusive for the claim but still careful about the broader attack path.

Manual filling sequence

When filling FARI by hand, use this order:

1. define the Frame;
2. attach or register the supplied material;
3. separate facts, assertions, inferences, assumptions, contradictions, and gaps;
4. decide the three sufficiency fields;
5. normalize findings and optional framework mappings;
6. choose conclusion, scenario disposition, confidence, action, and priority;
7. if software inventory matters, ingest an asset source and update component timelines;
8. capture a revision whenever the assessment meaning changed materially;
9. write scope boundary, rationale, recommendations, and acceptance criteria;
10. close the investigation only when the record can stand on its own.

Glossary

FARI

Framework for Aerospace Research and Investigation. It is the top-level framework that organizes aerospace assessment evidence into defensible investigation and consolidated reports.

Frame

The part of the workflow that defines client, mission context, scope, authorization, exclusions, assets, and claims before conclusions are made.

Acquire

The phase where supplied material is preserved and normalized into evidence, facts, assertions, inferences, assumptions, contradictions, gaps, and sufficiency decisions.

Relate

The phase where normalized material becomes findings, scenarios, optional framework mappings, and reportable technical meaning.

Inform

The phase where the report author chooses the conclusion, scenario disposition, required action, priority, and final reporting outputs.

Claim

A precise statement of expected behavior that an investigation evaluates. A FARI conclusion always answers a claim within a declared scope boundary.

Evidence-backed fact

A statement directly supported by preserved evidence without adding hidden interpretation.

Assertion

A useful statement supplied by the technical reporter that has not been independently demonstrated by the report author.

Inference

A report-author interpretation derived from facts, assertions, and surrounding context.

Assumption

A condition treated as true for the current analysis even though it is not demonstrated by the available material.

Contradiction

A meaningful conflict between observations, sources, or statements that affects the confidence or conclusion.

Gap

Missing information that prevents a stronger or broader conclusion.

Technical sufficiency

A qualitative decision about whether the evidence is enough to conclude the technical condition under test.

Reachability sufficiency

A qualitative decision about whether the path to exploitation or exposure is supported within the present scope.

Mission sufficiency

A qualitative decision about whether the mission or operational consequence is directly shown, partially supported, or still speculative.

Finding

A normalized reportable condition derived from the investigation and connected to evidence, assets, claims, and optional framework mappings.

Conclusion

The qualitative answer to the claim within the stated scope: Meets, Does Not Meet, Inconclusive, or Not Assessed.

Scenario disposition

A separate qualitative statement about the broader attack path: Demonstrated, Plausible, Not Demonstrated, or Not Evaluated.

Scope boundary

The exact limit of where the conclusion applies. It prevents readers from generalizing a narrow result beyond what the evidence supports.

Closed investigation

An immutable investigation record with sufficient context, evidence basis, decision fields, and required action to stand as a final report artifact.

Closed assessment

An immutable assessment whose gating investigations are closed and whose consolidated report is final for the declared scope.

Revision

A named snapshot of the assessment state, such as v1 or v2, captured for traceability and difference review.

Asset source

A preserved technical file attached to an asset, such as a dependency inventory, firmware image, binary, packet capture, SigMF file, log, or document. The source record retains the original bytes and metadata and may produce normalized inventory components when parsing is supported.

Inventory component

A tracked software package or dependency record derived from a structured asset source or dependency list and maintained over time with status and version changes.

Inventory event

A timestamped traceability record attached to an inventory component, used to record vulnerability discovery, version movement, status changes, and fix verification.